COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.6 · Password Security

Mestre CyberSec · **Aula 4.6 — Password Security** (6:22) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Password: COMPRIMENTO > complexidade (14+ é melhor); password manager (gera forte, guarda cifrado); passwordless (FIDO2/YubiKey, biometria, Magic link) = o futuro; NIST: sem troca forçada (incentiva fraca).

💡 Highlights que a prova CompTIA cobra

- Comprimento > complexidade (14 chars simples > 8 complexos)
- FIDO2/YubiKey = passwordless: a chave física que não pode ser phishing

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'length over complexity'=NIST 800-63B guidance

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.6 — Password Security)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Publicação Especial NIST 800-63B

Diretrizes de identidade digital do NIST que recomendam priorizar o comprimento da senha em vez da complexidade e desencorajam a rotação periódica forçada de senhas, pois essas práticas frequentemente levam a senhas fracas e previsíveis.

⚠️ ***Armadilha CompTIA:*** *Se a pergunta mostrar uma política exigindo troca de senha a cada 30/90 dias ou regras de complexidade extremas (caracteres especiais múltiplos), está em CONFLITO com o NIST 800-63B — escolha a alternativa alinhada ao NIST.*

• Gerenciador de Senhas (N/A)

Aplicativo que gera, armazena e preenche automaticamente senhas fortes, únicas e aleatórias em um cofre criptografado, permitindo que o usuário lembre apenas de uma senha mestra enquanto usa credenciais complexas em todos os serviços.

⚠️ ***Armadilha CompTIA:*** *Cenário de prova: 'usuários reutilizam senhas fracas em múltiplos sites' = solução correta é implementar um password manager corporativo, NÃO impor regras de complexidade mais rígidas.*

• FIDO2

Padrão aberto de autenticação da FIDO Alliance que combina WebAuthn (API de navegador) e CTAP2 (protocolo de autenticador) e permite logins sem senha e resistentes a phishing usando criptografia de chave pública.

⚠️ ***Armadilha CompTIA:*** *Distinguir FIDO2 de MFA comum: FIDO2 é inherentemente resistente a phishing porque a origem (origin) do site é validada criptograficamente — MFA por SMS ou OTP pode ser interceptado via phishing AiTM.*

• YubiKey (Y/A)

Chave física de segurança de hardware (USB/NFC) fabricada pela Yubico que implementa os protocolos FIDO2/WebAuthn para fornecer autenticação resistente a phishing e sem senha por meio de desafio-resposta criptográfico.

⚠️ ***Armadilha CompTIA:*** *Quando a questão mencionar 'hardware token resistente a phishing' ou a melhor forma de MFA para executivos/admins, pense em YubiKey/FIDO2 — é superior a OTP por SMS, TOTP em app ou push notification.*

• Autenticação Biométrica (N/A)

Autenticação baseada em características físicas ou comportamentais únicas (impressão digital, reconhecimento facial, íris, voz) — método primário sem senha, mas com desvantagens como taxas de falsa aceitação/rejeição e

impossibilidade de ser 'resetada'.

⚠️ ***Armadilha CompTIA:*** *Cuidado com a pegadinha clássica: 'Você não pode resetar uma credencial biométrica se ela for comprometida' — diferentemente de uma senha, um dedo vazado não pode ser trocado.*

• Magic Link (Link Mágico) (N/A)

Método de autenticação sem senha em que o servidor envia por e-mail um URL/token assinado, de uso único e com tempo limitado ao usuário; clicar no link autentica a sessão — depende inteiramente da segurança da conta de e-mail.

⚠️ ***Armadilha CompTIA:*** *Magic link NÃO é MFA; é 'something you have' (acesso ao e-mail). Se a conta de e-mail for comprometida, o atacante recebe todos os magic links — diferente de FIDO2 que é resistente a phishing.*

• Bloqueio de Conta (N/A)

Mitigação contra força bruta que desabilita uma conta após um limite de tentativas consecutivas falhas de autenticação dentro de uma janela de tempo definida, geralmente desbloqueando automaticamente após um período de espera.

⚠️ ***Armadilha CompTIA:*** *Distinguir de password spraying (que usa poucas senhas em muitas contas — lockout por conta NÃO ajuda). Para password spraying, a defesa correta é rate limiting por IP e bloqueio por IP, não por conta.*

• Ataque de Dicionário (N/A)

Ataque de senha que itera por uma lista pré-compilada de palavras comuns, senhas vazadas e variações previsíveis — derrotado evitando palavras reais e usando passphrases aleatórias.

⚠️ ***Armadilha CompTIA:*** *Se a questão perguntar POR QUE senhas longas são melhores que complexas curtas: a entropia vem do comprimento. 'HorseBatteryStapleCorrect' tem mais bits de entropia que 'P@ssw0rd!' mesmo sendo 'simples'.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A política de senha atual de uma empresa exige senhas de 8 caracteres com três classes de caracteres e força uma troca a cada 60 dias. Seguindo a NIST SP 800-63B, qual mudança de política a equipe de segurança deve recomendar?

A) Exigir no mínimo 14 caracteres, remover a expiração periódica a menos que haja suspeita de comprometimento e verificar novas senhas contra listas de vazamentos.

B) Manter a expiração de 60 dias, mas aumentar o mínimo para 10 caracteres e exigir quatro classes de caracteres.

C) Exigir que os usuários troquem senhas a cada 10 logins para limitar reutilização de credenciais.

D) Substituir a política de senhas por perguntas de segurança obrigatórias para toda recuperação de conta.

QUESTÃO 2 · CENÁRIO DE EXAME

Funcionários de uma empresa de médio porte reutilizam senhas em serviços de nuvem porque precisam memorizar muitas credenciais. A gerência quer reduzir a reutilização de senhas sem aumentar os chamados ao helpdesk. Qual controle é mais apropriado?

A) Implantar um gerenciador de senhas corporativo que gera senhas únicas e as armazena em um cofre criptografado.

B) Aplicar uma política de expiração de senha de 30 dias em todos os serviços de nuvem.

C) Exigir que os usuários armazenem senhas em uma planilha compartilhada com controle de acesso.

D) Desabilitar a autenticação multifator para serviços de nuvem para simplificar o acesso.

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros quer proteger executivos contra phishing de credenciais. O CISO solicita um método de autenticação resistente a phishing para usuários de alto risco. Qual solução atende melhor a esse requisito?

A) Códigos de uso único baseados em SMS.

B) Chaves de segurança FIDO2/WebAuthn, como YubiKeys.

C) Links mágicos enviados por e-mail com validade de 24 horas.

D) Senhas de uso único baseadas em tempo armazenadas em um aplicativo autenticador móvel.

QUESTÃO 4 · CENÁRIO DE EXAME

Uma prestadora de saúde quer que os clínicos se autentiquem em estações de trabalho sem digitar senhas, garantindo que as credenciais não possam ser compartilhadas. Qual combinação apoia melhor esse objetivo?

A) Nome de usuário/senha mais aplicativo autenticador TOTP.

B) YubiKey compartilhada do departamento mantida na estação de enfermagem.

C) Autenticador FIDO2 usando biometria da plataforma com WebAuthn.

D) Links mágicos enviados para uma conta de e-mail clínica compartilhada.

QUESTÃO 5 · CENÁRIO DE EXAME

Os logs da VPN mostram muitas tentativas de login falhas usando palavras comuns e variações de uma lista de senhas. A política atual bloqueia contas por 30 minutos após cinco falhas. Qual controle adicional mitiga melhor esse ataque de dicionário seguindo a orientação da NIST?

A) Limitar a taxa de tentativas de autenticação e verificar senhas contra listas de vazamentos e senhas comuns.

B) Reduzir o limite de bloqueio para duas tentativas e exigir trocas mensais de senha.

C) Desabilitar o bloqueio de conta para que atacantes não possam causar negação de serviço.

D) Exigir que as senhas incluam pelo menos uma letra maiúscula e um símbolo com 8 caracteres.

QUESTÃO 6 · CENÁRIO DE EXAME

Uma equipe de software propõe links mágicos para login de clientes a fim de reduzir o uso de senhas. Um arquiteto de segurança deve aprovar o design. Qual implementação é mais apropriada?

A) Link mágico reutilizável válido por 24 horas para melhorar a conveniência do usuário.

B) Link mágico de uso único com expiração curta, entregue via TLS e vinculado à sessão solicitante.

C) Token de link mágico armazenado permanentemente no armazenamento local do navegador para login contínuo.

D) Link mágico enviado por HTTP para evitar a sobrecarga de TLS no endpoint de autenticação.

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização habilita o Windows Hello for Business para que usuários façam login com PIN ou impressão digital em laptops gerenciados. Qual padrão fornece o mecanismo de autenticação subjacente resistente a phishing?

A) SAML 2.0

B) Concessão implícita do OAuth 2.0

C) Associação simples LDAP

D) FIDO2/WebAuthn

QUESTÃO 8 · CENÁRIO DE EXAME

Uma empresa implanta um gerenciador de senhas corporativo. O banco de dados do cofre é criptografado, mas os administradores estão preocupados com um atacante que comprometa um endpoint e obtenha o cofre criptografado. Qual controle reduz melhor o risco de comprometimento do cofre?

A) Exigir uma frase-senha mestra forte e aplicar MFA para desbloquear o cofre.

B) Configurar o cofre para usar uma senha mestra compartilhada por todos os usuários para simplificar a administração.

C) Armazenar a senha mestra junto com o cofre no endpoint para recuperação.

D) Desabilitar o bloqueio automático do cofre para que os usuários não precisem se autenticar novamente.

QUESTÃO 9 · CENÁRIO DE EXAME

Durante uma revisão de segurança, um gerente sugere exigir senhas complexas de 8 caracteres que expiram a cada 90 dias para melhorar a segurança de senhas. Qual recomendação se alinha melhor à orientação atual da NIST e reduz o risco relacionado a senhas?

A) Manter regras de complexidade de 8 caracteres e adicionar mais requisitos de caracteres especiais.

B) Aumentar o comprimento mínimo para pelo menos 14 caracteres, remover a expiração periódica forçada e bloquear senhas comumente vazadas.

C) Exigir que os usuários troquem senhas a cada 30 dias, mas permitir senhas mais simples.

D) Armazenar senhas usando criptografia reversível para que possam ser auditadas e recuperadas.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa quer migrar aplicações internas para autenticação sem senha. Qual abordagem de implantação é mais apropriada para uma grande empresa?

A) Pilotar chaves de segurança FIDO2 ou biometria da plataforma com aplicações-chave, registrar um autenticador de backup e então expandir e remover senhas conforme o suporte.

B) Remover imediatamente todas as senhas de todas as aplicações e depender apenas de links mágicos por e-mail.

C) Emitir uma YubiKey compartilhada por departamento para reduzir custos de hardware.

D) Usar códigos de uso único por SMS como único método sem senha para todos os administradores.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Exigir no mínimo 14 caracteres, remover a expiração periódica a menos que haja suspeita de comprometimento e verificar novas senhas contra listas de vazamentos.

A NIST SP 800-63B enfatiza o comprimento da senha em vez da complexidade de composição, recomenda verificação contra listas de senhas vazadas/comuns e desaconselha expiração periódica forçada porque ela geralmente leva a senhas mais fracas e previsíveis. As outras opções mantêm regras ineficazes de rotação/complexidade ou enfraquecem a segurança de recuperação.

Questão 2: Alternativa A — Implantar um gerenciador de senhas corporativo que gera senhas únicas e as armazena em um cofre criptografado.

Um gerenciador de senhas corporativo gera senhas fortes e únicas por site, armazena-as criptografadas e reduz o fardo de memorização, diminuindo diretamente a reutilização. A expiração incentiva mudanças previsíveis, planilhas não são um cofre seguro e desabilitar o MFA enfraquece a segurança.

Questão 3: Alternativa B — Chaves de segurança FIDO2/WebAuthn, como YubiKeys.

Chaves de segurança FIDO2/WebAuthn usam criptografia de chave pública vinculada à origem, tornando-as resistentes a phishing em tempo real e ataques de retransmissão de credenciais. SMS, TOTP e links mágicos por e-mail podem ser phishing, retransmitidos ou encaminhados.

Questão 4: Alternativa C — Autenticador FIDO2 usando biometria da plataforma com WebAuthn.

FIDO2 com WebAuthn e biometria da plataforma fornece autenticação sem senha e resistente a phishing, vinculada a um usuário e dispositivo. Uma chave de segurança compartilhada ou conta de e-mail compartilhada quebra a responsabilização individual e pode ser abusada.

Questão 5: Alternativa A — Limitar a taxa de tentativas de autenticação e verificar senhas contra listas de vazamentos e senhas comuns.

A orientação da NIST favorece limitação de taxa, monitoramento e verificação de senhas contra listas de vazamentos/comuns para reduzir o sucesso de adivinhação online. Limites agressivos de bloqueio podem criar DoS, desabilitar o bloqueio remove a proteção, e complexidade mínima com 8 caracteres é fraca.

Questão 6: Alternativa B — Link mágico de uso único com expiração curta, entregue via TLS e vinculado à sessão solicitante.

Links mágicos devem ser de curta duração, uso único, transmitidos com segurança e vinculados à sessão ou dispositivo para evitar replay e roubo de token. Links reutilizáveis, de longa duração, armazenados permanentemente ou transmitidos sem TLS aumentam o risco de tomada de conta.

Questão 7: Alternativa D — FIDO2/WebAuthn

O Windows Hello for Business usa conceitos FIDO2/WebAuthn e pares de chaves assimétricas vinculados ao dispositivo e ao usuário, fornecendo autenticação sem senha resistente a phishing. SAML, OAuth implícito e associação simples LDAP não fornecem o mesmo modelo de credencial vinculada ao dispositivo resistente a phishing.

Questão 8: Alternativa A — Exigir uma frase-senha mestra forte e aplicar MFA para desbloquear o cofre.

Um cofre de gerenciador de senhas depende da proteção do segredo mestre e do processo de desbloqueio. Uma frase-senha mestra forte mais MFA torna a quebra offline e o desbloqueio não autorizado muito mais difíceis. Senhas mestras compartilhadas, armazenar a senha mestra com o cofre e desabilitar o bloqueio automático prejudicam a segurança do cofre.

Questão 9: Alternativa B — Aumentar o comprimento mínimo para pelo menos 14 caracteres, remover a expiração periódica forçada e bloquear senhas comumente vazadas.

A NIST SP 800-63B prioriza comprimento, verificação de senhas vazadas e evitar rotação periódica forçada. Senhas/frases-senha mais longas fornecem mais entropia do que strings curtas e complexas, e bloquear senhas vazadas impede credenciais comprometidas conhecidas. Criptografia reversível e rotação frequente são práticas inseguras.

Questão 10: Alternativa A — Pilotar chaves de segurança FIDO2 ou biometria da plataforma com aplicações-chave, registrar um autenticador de backup e então expandir e remover senhas conforme o suporte.

Uma implantação faseada sem senha com FIDO2/WebAuthn ou biometria da plataforma permite testes, registro de backup e fallback, mantendo usabilidade e segurança. Remoção imediata, autenticadores compartilhados ou SMS apenas para administradores cria riscos de disponibilidade, responsabilização e phishing.